



BUILDING A BELIEVABLE
CYBERSECURITY
PROGRAMME
3FACTOR



SUMMARY

Building a cybersecurity programme that stakeholders trust and support is essential for any organisation seeking to defend against cyber threats. We believe that focusing on making a programme believable is the most effective way to achieve success.

A believable cybersecurity programme relies on 5 key factors:

- 1** Executive buy-in
- 2** Engaging the user base
- 3** Understanding risk in a meaningful way
- 4** Outsourcing wisely
- 5** Doing everything for a reason

We believe that cybersecurity leaders who focus on these 5 objectives can achieve their goals, defend their businesses and build deep, lasting trust in their organisations.

INTRO

In our experience, cybersecurity programmes consistently run into the same challenges – lack of engagement, lack of funding and tension with other parts of the organisation. These challenges slow down, and in some cases completely stop, progress towards improving security, leaving organisations open to attack.

The cybersecurity engagement cycle is familiar; security is a secondary consideration, becoming a priority only after a breach or attack occurs. Only then are engagement, funding and resources applied – with varying degrees of effectiveness. Once the breach or attack has become history, the cycle repeats itself with no real progress having been made toward a more mature approach to cybersecurity.

To tackle these problems, we believe that CISOs and cybersecurity leaders should focus on building believable cybersecurity programmes.

WHAT ARE WE TRYING TO AVOID?

The alternative to believable cybersecurity is, in many organisations, the status quo. The status quo will be instantly recognisable to security professionals – too often cybersecurity is bureaucratic and an impediment to business objectives.

There are common symptoms that we have seen across dozens of organisations:

- ⦿ Security policies are viewed as arbitrary, pointless rules
- ⦿ Enforcement of security policies is often left to businesses and compliance is not tracked
- ⦿ The security team is not proactively engaged by other parts of the organisation
- ⦿ In projects, the security team is more often a blocker than a constructive collaborator
- ⦿ Nobody from security gets invited to parties

As a result, security is not considered a priority. Business and IT project managers avoid engaging the cybersecurity team until the final phases of a project, when it is too late and too expensive to address security concerns. In some cases, cybersecurity teams may not even find out about projects until they go live, with project managers adopting the “better to ask forgiveness than permission” principle. This puts cybersecurity leaders in a situation where they either have to approve projects in spite of security issues, or risk blocking revenue-generating activities.

WHAT DO WE MEAN BY BELIEVABLE CYBERSECURITY?

Believable cybersecurity is about building a credible security programme that your users, executives and stakeholders genuinely trust and believe in. Gaining that trust enables your security programme to move faster, face less resistance, and work with, rather than against, the rest of your organisation.

To gain trust, cybersecurity teams must align with the objectives of the organisation. The primary objectives may be growing the business or increasing profit, but very rarely will one of them be securing information. The harsh reality is that many organisations simply would not bother with security if there wasn't a risk to primary business objectives.

So cybersecurity teams must demonstrate how security can support those primary objectives by operationalising the five factors which make cybersecurity programmes believable.



HOW CAN WE DEFINE BELIEVABLE SECURITY?

Here are some principles to define this approach:

- ⦿ Security must be a meaningful exercise with valuable outcomes
- ⦿ Security must be aligned with business objectives
- ⦿ All stakeholders must be able to see the value that the programme brings
- ⦿ Users should experience the minimum possible inconvenience
- ⦿ Security objectives should be achievable
- ⦿ Security should be measurable

Achieving these principles is not simple. In reality cybersecurity teams have to balance competing priorities, work with finite resources and satisfy complex stakeholder needs.

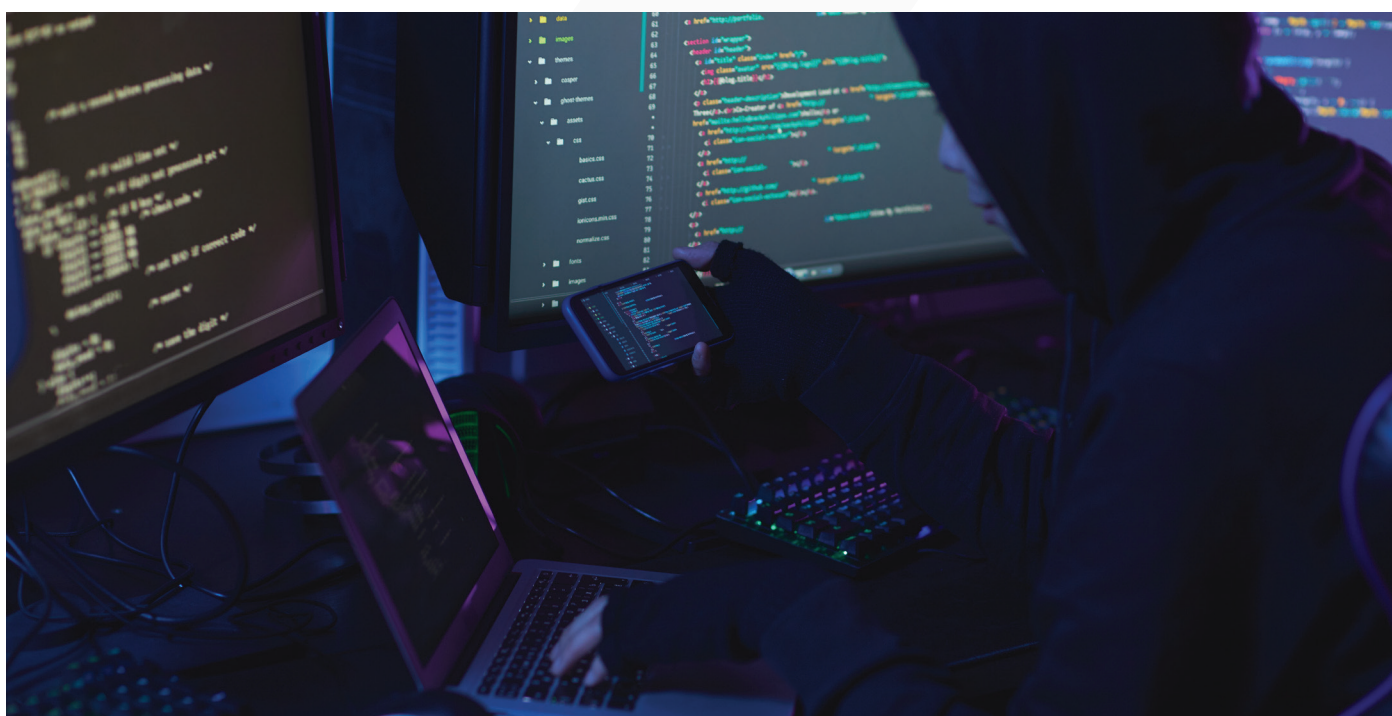
FINDING THE BALANCE BETWEEN ORGANISATIONAL OBJECTIVES AND CYBERSECURITY

What a believable programme looks like depends on the objectives of the organisation and the amount of risk it's willing to take in pursuit of those objectives. The security programme must align – as much as possible – with both short and long term organisational objectives.

In some cases, cybersecurity can directly support organisational objectives. For example, maintaining security of customer data has a direct impact on customer retention. However, in other cases organisational objectives may be hindered by cybersecurity controls. A common example is delaying the launch of new technology to complete security review activities.

It's necessary to identify which organisational objectives are directly supported by security and which objectives may conflict with security concerns. The former group can be used as examples to build support and demonstrate the value of cybersecurity to the organisation, whilst the latter must be carefully managed to limit disruption. A deep understanding of which organisational objectives are most important is essential.

Ultimately, this becomes a question of timing, prioritisation and risk. Building a believable security programme is not about doing everything perfectly, rather it requires doing the right things at the right time by implementing the following five critical steps.



5 CRITICAL STEPS TO BUILD A BELIEVABLE SECURITY PROGRAMME

1. EXECUTIVE BUY-IN

Why it's important

- ⦿ Executive commitment is absolutely crucial. There is literally no point trying to do cybersecurity properly if executives don't care and do not provide support.
- ⦿ You need two things from executives - money and practical, sustained support. Without these, it's very difficult to make any progress with your security programme. Here's the problem - everyone else in your organisation wants money and support. So you have to be able to explain why you should get it.

How to do it

- ⦿ The traditional way of gaining executive support is fear-mongering, but when predictions of the impending apocalypse don't come true executives start to worry about something else. It's much more effective to offer peace-of-mind and even better to offer business benefits.
- ⦿ Going back to our earlier statement about aligning security with business objectives; identifying those organisational objectives which cybersecurity directly supports is an essential part of gaining executive support. Here are some common examples:
 - ◆ Supporting customer retention by maintaining security of customer data
 - ◆ Contributing to sales by maintaining availability of systems
 - ◆ Supporting compliance obligations
 - ◆ Avoiding negative press which could impact stock price
 - ◆ Supporting profitability by avoiding expensive incident response and recovery
- ⦿ Ask executives what they see as being wrong with cybersecurity - get them to talk about past negative experiences with cybersecurity and think about how you can fix those problems or stop them from happening again.
- ⦿ Ultimately, every conversation you have with executives should be centred around how cybersecurity can support business objectives.

2. ENGAGE THE USER BASE

Why it's important

- ◎ Depending on your school of thought, users are either your biggest risk or your first line of defence. Either way, engaging them is crucial. Everyone in an organisation must understand that security is a shared responsibility, and not just something that is done by someone else. That means helping your users to understand security risks and inspiring them to support you in defending against those risks. If you get this right, you have a whole organisation full of people looking out for security risks, who all know exactly what to do to help you make the organisation more secure.

How to do it

- ◎ The key to engaging your users is to consider the relationship as a two-way conversation.
- ◎ It's not enough to push out an e-learning module once a year and assume everyone will be passionate about security for 12 months. You have to listen to users – understand their concerns and the risks they see every day.
- ◎ Most importantly, understand how you can make their lives easier. Most organisations have controls that actively disrupt the work of users, which often force users to take shortcuts.
- ◎ Users have a choice. If you don't convince them to make the right choice, they will make the easy one. Even better if you can design the choice out of the process. For example, if cloud file-sharing is useful for your users, simply blocking file-sharing sites will likely lead to users choosing alternative, even less secure methods like email or unencrypted USB devices. Listening to your users' needs and providing a secure, approved file-sharing site will result in a better user experience and less security risk.



3. UNDERSTAND CYBER RISK IN A MEANINGFUL WAY

Why it's important

- ⦿ There is no single version of security. The right thing at the right time is different for every organisation. So while checklists and standards are helpful, the only way to genuinely understand what you should be doing is to understand the specific risks to your organisation. Risk management will help you to make decisions in a consistent, evidence-based way and will be your most valuable tool in balancing cybersecurity with business priorities.
- ⦿ It's important to have a meaningful understanding of risk that goes beyond numbers in a spreadsheet and gives you genuine insight into how a cyber attack would affect your organisation.

How to do it

- ⦿ Risk management can be overwhelming and, often, a pointless exercise in creating spreadsheets. Don't worry too much about formal risk management frameworks - they can be useful, but they can also be a huge distraction. Instead listen to your users and stakeholders to understand where they see risks.
- ⦿ Here is a simplified distillation of every risk management framework ever: figure out what valuable stuff you have > figure out what bad things could happen to that stuff > figure out how to stop those bad things happening.
- ⦿ Start with figuring out what you want to protect (your "assets") - that could be customer data, intellectual property or industrial control systems, but most likely it will be whatever your organisation makes money from.
- ⦿ Think about what might happen to the thing you want to protect ("risks") - normally this will be some variation of someone stealing it or breaking it.
- ⦿ Stopping the bad things from happening ("controls") is the difficult part, but generally the answer is not an expensive tool. At this point you need to decide what you can afford to do and what you can live with. Again, you will need to consider what will support wider business objectives most effectively.
- ⦿ Clearly, this is a gross oversimplification of something that requires a lot of experience and expertise to get right, but the point is: don't make it any harder than it has to be. If your approach diverts from considering those three factors (assets, risks, controls), you're wasting your time.
- ⦿ Demonstrating a genuine understanding of risk, which makes sense to your stakeholders, will significantly improve engagement with your cybersecurity programme.

4. OUTSOURCE WISELY

Why it's important

- ◎ Cybersecurity is a huge discipline and it's only getting bigger. The depth and breadth of expertise needed to implement and operate a full suite of controls is impossible to achieve for virtually every organisation. There are only a handful of organisations on the planet that realistically have the resources to run every element of a security programme in-house. For everyone else, strategic outsourcing is essential. It will allow you to do far more than you can do alone, much faster, much more effectively and with far greater return-on-investment.

How to do it

- ◎ In the simplest terms, strategic outsourcing means figuring out what someone else can do cheaper and/or better than you can do it.
- ◎ This means identifying the skills you have in your team - what can your team do and do well? Understand how your team can add the most value - often this is in building relationships, evangelising security and driving high-priority projects. Anything outside of the core competencies of your team should be considered for outsourcing to an expert vendor who can deliver better than your team and allow your team to stay focused on their priorities.
- ◎ The question of what to outsource is different for every organisation. Some things are obvious - it almost always makes sense to outsource penetration testing, for example - but most things will depend on the size and capability of your team, your tech stack and what you need to be in direct control of.
- ◎ A lot of organisations are scared of outsourcing cybersecurity activities. You shouldn't be, as long as you keep these simple questions in mind:



5. DO EVERYTHING FOR A REASON

Why it's important

- ⦿ The most dangerous trap for any cybersecurity team is this idea: We must do something about security... this is something... therefore we must do this.
- ⦿ You should not do anything in security unless there is a good reason to do it. This sounds obvious, but we repeatedly see security teams doing things either because:
 - ◆ They've always done it;
 - ◆ They have to justify the number of people they have; or
 - ◆ They need to be seen to be doing something

This is particularly dangerous because these types of activities often irritate and disrupt stakeholders without providing any value, which undermines the credibility of the cybersecurity programme.

- ⦿ In the long-term, an accumulation of these activities can distract the cybersecurity team from more important tasks. It's essential to avoid having a cybersecurity team that doesn't have time to drive the patching of a critical vulnerability because everyone is too busy filling in spreadsheets.

How to do it

- ⦿ It's genuinely better to do nothing than to do something pointless. Pointless tasks burn goodwill and turn people against your cybersecurity team.
 - ◆ Firstly, get rid of any existing pointless activities. Many cybersecurity teams are overworked and eliminating unnecessary work allows for more time to focus on critical tasks, think about strategic priorities and keep up-to-date with new trends.
 - ◆ Secondly, avoid introducing any more pointless activities. Ask these questions about any new cybersecurity initiative:
 - Does it reduce a risk?
 - Does it reduce the risk enough to justify the cost and effort of the initiative?
 - Will it help the organisation to achieve its objectives?

If you can answer yes to all of these questions, go ahead. If not, either don't do it or find a way to do it that satisfies those three questions.

- ⦿ These simple steps will help you to build a cybersecurity programme that only does meaningful work.

HOW CAN 3FACTOR HELP?

Visit 3Factor.com to learn about how we can help you to build a believable Cybersecurity programme